

Políticas de Seguridad de la Información

BANCO LUNA LLENA

Nombre del equipo: CACTUCITOS

Integrantes:

- Josue Nisthaus
- Carlos Caba
- Luciana Velasco
- Daniela Guzman
- José Manzaneda

LA PAZ, BOLIVIA - 2026

ADVERTENCIA

Este documento y su contenido se clasifica como **USO INTERNO**, contiene información propia del Banco Luna Llena, siendo de uso exclusivo del personal autorizado de la institución. No puede ser distribuida ni divulgada a personas ajenas a la misma sin autorización de la Máxima Autoridad Ejecutiva, en forma total o parcial; la reproducción o divulgación NO autorizada de este material estará sujeta a sanciones que correspondan de acuerdo con la legislación vigente y a las políticas y normas del Banco Luna Llena.

Versión: 2.0

Fecha: 13/04/2026

Aprobado por: Gerente General del Banco Luna Llena

Fecha de vigencia: 13/04/2026

Histórico de revisiones del Documento

Versión	Fecha	Detalle de Revisión y Cambios
1.0	11/03/2026	Creación del documento
2.0	13/04/2026	Modificación de formato
3.0	19/05/2026	Agregacion y actualizacion politicas

Indice

1. Objetivo	4
2. Alcance	4
3. Glosario de términos	4
4. Documentos internos relacionados	6
5. Documentos externos relacionados	7
6. Directrices generales	7
7. Políticas	7
7.1 Políticas de gestión de seguridad de información	7
7.2 Planificación estratégica y organización de los recursos de tecnologías de la información	8
7.3 Seguridad de la información física y lógica	8
7.4 Políticas de administración de usuarios y accesos	8
7.5 Políticas de seguridad de servicios de computación en la nube	9
7.6 Políticas de seguridad física de los activos de información	9
7.7 Políticas de gestión de incidentes de seguridad	9
7.8 Políticas de continuidad del negocio y recuperación ante desastres	10
7.9 Políticas de desarrollo seguro de software	10
8. Incumplimientos	10
9. Aprobación	10

1. Objetivo

Definir las directrices a seguir en el Banco Luna Llena para la implementación y gestión del Sistema de Gestión de Seguridad de la Información de acuerdo con los objetivos estratégicos de la institución, la estrategia de seguridad de información y las disposiciones legales vigentes.

2. Alcance

El presente documento aplica a la Alta Gerencia, unidades organizacionales, empleados, directivos y proveedores de servicios del Banco Luna Llena cuando corresponda. También aplica al Área de Tecnologías de Información y sus 13 profesionales. Todos son responsables de su cumplimiento y aplicación.

3. Glosario de términos

Para efectos del presente documento se utilizan las siguientes definiciones:

Activo de información: Dato, información, sistema o elemento relacionado con la tecnología de la información que tiene valor para el Banco Luna Llena y requiere protección.

Acuerdo de nivel de servicio (SLA): Documento que estipula las condiciones de un servicio en función a parámetros objetivos, establecidos de mutuo acuerdo entre un proveedor externo y el banco.

Amenaza: Causa potencial de un incidente no deseado que puede resultar en daño a un sistema, proceso o activo de información del banco.

Área de exclusión: Área de acceso restringido identificada en las instalaciones del banco, que requiere medidas máximas de protección y control de ingreso.

Autenticación multifactor (MFA): Mecanismo de verificación de identidad que combina al menos dos de los siguientes factores: algo que el usuario sabe, algo que el usuario tiene, o algo que el usuario es.

Centro de Procesamiento de Datos (CPD): Infraestructura tecnológica e instalación donde están ubicados los recursos utilizados para el procesamiento de información del banco.

Centro de Procesamiento de Datos Alterno (CPDA): Infraestructura tecnológica ubicada en una localización geográfica distinta al CPD principal, que permite el procesamiento de información de forma alterna ante una contingencia.

Cifrado: Proceso mediante el cual la información es alterada lógicamente mediante claves, con el objetivo de que personas no autorizadas no puedan interpretarla, copiarla ni utilizarla.

Clasificación de la información: Esquema que categoriza la información del banco según su criticidad y sensibilidad, determinando los controles de acceso y protección aplicables.

Computación en la nube (Cloud Computing): Modelo de acceso bajo demanda, a través de red, a recursos informáticos compartidos (servidores, almacenamiento, aplicaciones) que pueden ser aprovisionados con mínimo esfuerzo de administración.

Confidencialidad: Propiedad que garantiza que la información es accesible únicamente para el personal autorizado.

Disponibilidad: Propiedad que asegura el acceso a la información en el tiempo y la forma en que sea requerida por los usuarios autorizados.

Gerencia de Seguridad de la Información (GSI): Instancia responsable de la administración y control de la seguridad de los recursos de información del banco, con independencia funcional y operativa del área de TI y de auditoría interna.

Gerencia de Tecnologías de Información (GTI): Instancia ejecutiva responsable de la gestión de los recursos tecnológicos del banco y de la ejecución del PETI.

Incidente de seguridad de la información: Suceso o serie de sucesos que tienen probabilidad significativa de comprometer las operaciones del banco, amenazar la seguridad de la información o los recursos tecnológicos.

Integridad: Propiedad que busca mantener con exactitud la información completa tal cual fue generada, sin ser manipulada o alterada por personas o procesos no autorizados.

MAE (Máxima Autoridad Ejecutiva): Gerente General del Banco Luna Llena, responsable de la implementación y cumplimiento de las políticas y estrategias aprobadas por el Directorio.

No repudio: Condición que asegura que el emisor de una información no puede rechazar su transmisión o contenido, y que el receptor no puede negar su recepción.

Plan de Continuidad del Negocio (BCP): Documento que contempla la logística para restaurar los servicios y aplicaciones críticas parcial o totalmente suspendidas dentro de un tiempo predeterminado, tras una interrupción o desastre.

Plan de Recuperación ante Desastres (DRP): Documento que establece los procedimientos técnicos para la recuperación de la infraestructura tecnológica y los sistemas de información ante un evento de desastre.

Plan Estratégico de Seguridad de la Información (PESI): Documento que define los objetivos estratégicos de seguridad de la información del banco para el período 2025–2030.

Plan Estratégico de Tecnología de la Información (PETI): Documento que define el rumbo tecnológico del banco para el período 2025–2030, alineado al Plan Estratégico Institucional (PEI).

Política de Seguridad de la Información (PSI): Conjunto de directrices aprobadas por el Directorio que orientan la gestión de la seguridad de la información en el banco.

Principio de menor privilegio: Criterio que establece que cada usuario o proceso del sistema de información debe operar únicamente con los privilegios estrictamente necesarios para cumplir las funciones que tiene asignadas.

Propietario de la información: Responsable formalmente designado para controlar la producción, desarrollo, mantenimiento, uso y seguridad de un activo de información.

Respaldo o copia de seguridad (Backup): Copia de datos e información almacenada en un medio digital, generada periódicamente con el propósito de utilizarla en casos de emergencia o contingencia.

RPO (Recovery Point Objective): Tiempo máximo de pérdida de datos aceptable para el banco en caso de una interrupción; define el punto en el tiempo al que se puede restaurar la información.

RTO (Recovery Time Objective): Tiempo máximo admisible para la restauración de un sistema o proceso crítico tras una interrupción.

Segregación de funciones: Principio de control interno que consiste en distribuir tareas y responsabilidades críticas entre distintos funcionarios para reducir el riesgo de errores o acciones no autorizadas.

Seguridad de la información: Conjunto de medidas y recursos destinados a resguardar y proteger la información y los activos de información, buscando mantener su confidencialidad, integridad, disponibilidad, confiabilidad, autenticación, cumplimiento y no repudio.

Sistema de información: Conjunto organizado e interrelacionado de procedimientos de recopilación, procesamiento, transmisión y difusión de información que interactúan entre sí para lograr un objetivo.

Sitio externo de resguardo: Ambiente externo a las instalaciones del banco y al CPDA, donde se almacenan los medios de respaldo, documentación y recursos de TI críticos para soportar los planes de continuidad y contingencias tecnológicas.

Vulnerabilidad: Debilidad de un activo de información, proceso o control que puede ser explotada por una amenaza, incrementando el riesgo de ocurrencia de un incidente de seguridad.

4. Documentos internos relacionados

DESCRIPCIÓN	CÓDIGO
Plan Estratégico Institucional 2025–2030	PEI-001
Plan Estratégico de Seguridad de la Información 2025–2030	PESI-001
Plan Estratégico de Tecnología de la Información 2025–2030	PETI-001
Organigrama Funcional del Área de Tecnologías de Información	ORG-TI-001
Inventario de Infraestructura de TI	INF-TI-001
Manuales de Funciones por Cargo (13 cargos)	MF-TI-001 al 013
Reglamento Interno de Trabajo	RIT-001
Plan de Recuperación ante Desastres (DRP)	DRP-001

5. Documentos externos relacionados

Estándar ISO/IEC 27001 – Sistema de Gestión de Seguridad de la Información.

PCI DSS v4.0 – Payment Card Industry Data Security Standard.

NIST CSF 2.0 – Marco de Ciberseguridad (NIST).

CIS Controls v8 – Controles técnicos de ciberseguridad.

OWASP Top 10 2021 – Riesgos críticos en aplicaciones web.

COBIT 2019 – Marco de gobierno y gestión de TI.

Normativa ASFI – Autoridad de Supervisión del Sistema Financiero de Bolivia.

6. Directrices generales

6.1 La información es considerada para el Banco Luna Llena como un recurso valioso; por consiguiente, será administrada, gestionada, resguardada y protegida, cualquiera sea la forma en que se encuentre o se desarrolle (formato físico, electrónico, en pantallas, medios magnéticos o en el conocimiento del personal).

6.2 El banco adoptará las medidas necesarias para el resguardo y tratamiento de la información, con el objetivo de proteger su **confidencialidad, integridad y disponibilidad** como criterios principales y la **confiabilidad, autenticación, cumplimiento y no repudio** como criterios complementarios, de acuerdo con la normativa y legislación vigentes.

6.3 El banco destinará los recursos necesarios para el estudio, desarrollo, implementación y mantenimiento de la seguridad de la información, de acuerdo con la estrategia del negocio.

6.4 El banco establece la aplicación de sanciones disciplinarias de acuerdo con el Reglamento Interno de Trabajo y la legislación vigente, por el incumplimiento a las políticas establecidas y a documentos normativos relacionados.

6.5 Se establece la Gestión de la Seguridad de Información a través de las siguientes políticas:

7. Políticas

7.1 Políticas de gestión de seguridad de información

El Banco Luna Llena delega al Gerente de Seguridad de la Información la gestión de la seguridad de información, debiendo éste recomendar los controles y mitigaciones que considere necesarios en ese ámbito.

La seguridad de información se precautela a través de compromisos contractuales con los empleados y la difusión y cumplimiento de estas políticas. Las responsabilidades sobre seguridad de información están incorporadas en los Manuales de Funciones de los 13 cargos del Área de TI.

El Banco Luna Llena utiliza el estándar ISO 27001 para la Gestión de Seguridad de Información, complementado con NIST CSF 2.0 y CIS Controls v8, de forma complementaria al cumplimiento de la normativa y legislación vigentes en el rubro.

7.2 Planificación estratégica y organización de los recursos de tecnologías de la información

El banco determina el Plan Estratégico de Tecnología de la Información (PETI 2025–2030), alineado al Plan Estratégico Institucional y a la Estrategia de Seguridad de la Información.

La MAE delega al Gerente de TI el seguimiento a las tendencias tecnológicas, la gestión de los recursos de TI y el cumplimiento normativo, en coordinación con el Gerente de Seguridad de la Información.

El Comité de Tecnología de la Información es la instancia responsable del seguimiento y control a los requerimientos tecnológicos y a la ejecución del PETI.

7.3 Seguridad de la información física y lógica

El banco determina las directrices para la seguridad de la información física y lógica a partir de la identificación de sus recursos (sistemas, aplicaciones y servicios), de acuerdo al impacto sobre su confidencialidad, disponibilidad e integridad.

Determina la clasificación de la información dentro de las siguientes categorías: 1.

- a) Confidencial o crítica
- b) Uso interno o privado
- c) Uso general o público

La gestión de la seguridad física y lógica considera normas para la revelación, manipulación, resguardo, difusión y destrucción de la información.

El intercambio de información dentro del banco parte del principio de menor privilegio. La información compartida con terceros contará con acuerdos de confidencialidad.

El Gerente de Seguridad de la Información tiene autorización para ejecutar procesos de sanitización de medios de almacenamiento y equipos tecnológicos pertenecientes al banco.

7.4 Políticas de administración de usuarios y accesos

La asignación de accesos cumplirá los criterios de menor privilegio y segregación de funciones. El acceso y otorgación de privilegios se efectúan de acuerdo con las funciones asignadas en los Manuales de Funciones de cada cargo.

Los propietarios de usuarios son únicos responsables del correcto uso y custodia de sus credenciales. No se permite el uso de un código de usuario ajeno ni la divulgación de contraseñas a terceros.

La autenticación multifactor (MFA) es **obligatoria** para todos los accesos a sistemas críticos del banco, conforme al objetivo OS3 del PESI.

Las contraseñas son confidenciales, deben cumplir los criterios de complejidad definidos por la GSI y renovarse periódicamente según los procedimientos establecidos.

7.5 Políticas de seguridad de servicios de computación en la nube

El banco define los criterios de seguridad para la gestión, tratamiento y protección de la información en servicios de computación en la nube, considerando ISO 27001, ISO 27018 y la normativa ASFI vigente.

Los servicios cloud para procesos core contarán con un Proyecto de Implementación del Servicio de Computación en la Nube, elaborado conforme a lo requerido por la normativa ASFI vigente, el cual deberá ser presentado a la Autoridad de Supervisión del Sistema Financiero para su no objeción previa a la contratación del servicio. Para procesos de soporte, los resultados de la evaluación de riesgos de seguridad quedarán documentados y disponibles a requerimiento de la MAE o el regulador.

Se establece que los proveedores de servicios de computación en la nube sigan al menos los siguientes criterios:

- a) Los datos personales solo podrán ser tratados de acuerdo con los requisitos del banco.
- b) El proveedor aceptará evaluaciones periódicas de sus servicios, proporcionando soporte y documentación necesaria.
- c) El proveedor brindará herramientas respetando los derechos de acceso, rectificación, cancelación y oposición.
- d) Las brechas de seguridad serán documentadas y reportadas oportunamente al banco.
- e) La publicación de datos solo puede ser bajo obligación legal, informando al banco antes de cumplirla.
- f) El proveedor cumplirá la legislación boliviana.

Todo contrato con proveedor externo de tecnología de la información incluirá un Acuerdo de Nivel de Servicio (SLA) como documento parte del contrato, cuyos parámetros mínimos cubrirán: tipo de servicio, soporte y asistencia, seguridad de datos, garantías del sistema, disponibilidad, tiempos de respuesta, conectividad y multas por caída del servicio, según corresponda, alineados a los resultados del análisis y evaluación de riesgos de seguridad de la información del banco.

7.6 Políticas de seguridad física de los activos de información

El banco establece controles de seguridad física para proteger el acceso a las áreas de exclusión como el centro de cómputo en la Sede Central (zona Achumani), salas de telecomunicaciones y otras áreas donde se genera, procesa o almacena información institucional.

Se establecen límites de acceso de acuerdo con la zonificación definida según la clasificación de la información y las funciones del personal autorizado. El acceso está determinado en la Matriz de Acceso Físico.

El banco define e implementa parámetros y procedimientos para detectar posibles brechas de seguridad física y ejercer acciones de corrección oportunas, así como controles para proteger los activos de amenazas físicas y ambientales.

7.7 Políticas de gestión de incidentes de seguridad

El banco establece un proceso formal de gestión de incidentes de seguridad coordinado por la Gerencia de Seguridad de la Información, orientado a detectar, contener y resolver incidentes de manera oportuna.

Todo incidente debe ser reportado de inmediato al Gerente de Seguridad de la Información. Los incidentes críticos serán escalados a la Gerencia General y comunicados al regulador ASFI cuando corresponda.

Los incidentes serán registrados y analizados para incorporar lecciones aprendidas en la mejora continua del SGSI. Se realizarán pruebas de penetración periódicas coordinadas por la GSI.

7.8 Políticas de continuidad del negocio y recuperación ante desastres

Los sistemas críticos, incluyendo el Core Bancario y los servicios digitales, deben mantener una disponibilidad mínima del 99.9% anual.

Se definen los siguientes objetivos de recuperación: **RTO ≤ 4 horas y RPO ≤ 2 horas** para sistemas críticos, a ser verificados mediante pruebas periódicas de Disaster Recovery.

El Plan de Recuperación ante Desastres (DRP) será documentado, mantenido, actualizado y probado regularmente por la GSI y la Subgerencia de Operaciones y Gestión de Datos. Los respaldos periódicos de datos financieros y sistemas críticos son obligatorios.

Los medios de respaldo son probados periódicamente por la instancia responsable de la seguridad de la información, y los resultados de dichas pruebas son documentados y archivados. El sitio externo de respaldo mantiene un mínimo de diez (10) años de información crítica del banco. Todo traslado físico de medios digitales de respaldo se realiza bajo controles de seguridad formales que eviten la exposición no autorizada de la información contenida en ellos.

7.9 Políticas de desarrollo seguro de software

Todo desarrollo de software del banco, incluyendo la plataforma de banca en línea y la aplicación móvil, incorporará controles de seguridad desde las etapas tempranas del ciclo de desarrollo, siguiendo el estándar OWASP Top 10.

La Subgerencia de Desarrollo y Proyectos aplicará la metodología Scrum incorporando revisiones de seguridad en cada sprint. El Analista de Calidad verificará el cumplimiento de los estándares de seguridad antes de aceptar cada entregable.

Toda aplicación debe someterse a pruebas de seguridad antes de pasar a producción, incluyendo revisión de código y pruebas de vulnerabilidades. Los componentes de terceros serán evaluados y mantenidos actualizados.

8. Incumplimientos

Cualquier incumplimiento a lo señalado en el presente documento será sancionado de acuerdo al Reglamento Interno de Trabajo (Manual de incumplimientos y sanciones).

9. Aprobación

El presente documento ha sido aprobado por las instancias correspondientes, momento a partir del cual es puesto en vigencia y a disposición del personal dependiente del Banco Luna Llena.